

Apache, and the certificate nobody trusts

Apache serving over both HTTP and HTTPS, with a certificate it signed itself. Every block below came out of a running lab, including the moment a client refuses that certificate and the reason it gives.

Command `qlab run apache-lab`

VM `apache-lab`, ports 80 and 443 forwarded to dynamic host ports

Credentials `labuser` / `labpass`

Outcome `qlab test apache-lab` → 6 exercises, 35 checks, all passed

1. What is running

```
Server version: Apache/2.4.52 (Ubuntu)
Server built:   2026-07-06T16:41:46
active
enabled
```

```
root      2242      1 /usr/sbin/apache2 -k start
www-data  5036      2242 /usr/sbin/apache2 -k start
www-data  5037      2242 /usr/sbin/apache2 -k start
```

One `root` process and a set of `www-data` children. The root process exists to bind ports 80 and 443 — below 1024, so privileged — and to re-read the configuration; the children handle requests without privilege. Apache calls the scheme that decides how those children are arranged an **MPM**:

```
authz_core_module (shared)
mpm_event_module (shared)
rewrite_module (shared)
ssl_module (shared)
```

`mpm_event` is the modern default: a small number of processes, each with many threads, and connections that are merely waiting are handed back to a listener instead of pinning a worker. The old `mpm_prefork` — one process per connection — is still what you get when a module is not thread-safe, which in practice means classic `mod_php`.

The rest of that list is Apache's other defining trait: almost everything is a module you switch on. `ssl_module` is why 443 answers at all, and `a2enmod / a2dismod` are how the switch is thrown.

```
LISTEN 0      511      *:80  *:*
```

```
LISTEN 0      511      *:443 *:*
```

2. The sites

```
total 0
lrwxrwxrwx 1 root root 35 Sep 14 09:39 default-ssl.conf -> ../sites-available/default-ssl.conf
lrwxrwxrwx 1 root root 31 Sep 14 09:39 default.conf -> ../sites-available/default.conf

000-default.conf
default-ssl.conf
default.conf
```

Apache separates *available* from *enabled* the same way nginx does, with `a2ensite` and `a2dissite` managing the symlinks. Here both the plain and the TLS site are on.

```
<VirtualHost *:443>
    ServerName localhost
    DocumentRoot /var/www/html
    SSLEngine on
```

```
SSLCertificateFile /etc/ssl/certs/apache-selfsigned.crt
SSLCertificateKeyFile /etc/ssl/private/apache-selfsigned.key
<Directory /var/www/html>
    Options Indexes FollowSymLinks
    AllowOverride All
    Require all granted
</Directory>
</VirtualHost>
```

3. The certificate, and why a client rejects it

```
certificate: /etc/ssl/certs/apache-selfsigned.crt
subject=CN = localhost, O = apache-lab, C = US
issuer=CN = localhost, O = apache-lab, C = US
notBefore=Sep 14 09:39:27 2026 GMT
notAfter=Sep 14 09:39:27 2027 GMT
```

Read the two lines together: **subject and issuer are the same**. That is the definition of a self-signed certificate — it vouches for itself, and there is no authority above it that a client already trusts.

The consequence is not subtle:

```
$ curl -I http://localhost/
HTTP/1.1 200 OK
Date: Mon, 14 Sep 2026 09:40:56 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Mon, 14 Sep 2026 09:40:45 GMT
ETag: "15-65b6e3a7a452b"

$ curl -Ik https://localhost/
HTTP/1.1 200 OK
Date: Mon, 14 Sep 2026 09:40:56 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Mon, 14 Sep 2026 09:40:45 GMT
ETag: "15-65b6e3a7a452b"

$ curl -I https://localhost/ (no -k, so the chain is verified)
curl: (60) SSL certificate problem: self-signed certificate
More details here: https://curl.se/docs/sslcerts.html

curl failed to verify the legitimacy of the server and therefore could not
```

The same page over HTTP, over HTTPS with `-k`, and over HTTPS without it. `-k` means "do not verify"; without it the client checks the chain, finds it ends at a certificate nobody vouched for, and refuses before sending the request.

This is not a broken certificate

The encryption is exactly as strong either way. What is missing is *identity* — a third party asserting that this server is who it claims to be. A self-signed certificate is entirely appropriate inside a lab; on the public internet it is what an interception attack looks like, which is why clients refuse it loudly.

4. Apache checks its own configuration

```
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using
fec0::5054:ff:fe12:3456. Set the 'ServerName' directive globally to suppress this message
Syntax OK
```

`Syntax OK` is the answer you want before a reload. The warning above it is worth reading rather than ignoring: with no global `ServerName`, Apache guesses a name for itself from the host's addresses. It still works, but any behaviour that depends on the server's own name — redirects it generates, virtual host matching — is then resting on a guess.

```
[Mon Sep 14 09:40:53.682319 2026] [ssl:warn] [pid 2242:tid 140274110928768] AH01906: localhost:443:0
server certificate is a CA certificate (BasicConstraints: CA == TRUE !?)
[Mon Sep 14 09:40:53.682412 2026] [mpm_event:notice] [pid 2242:tid 140274110928768] AH00489: Apache/
2.4.52 (Ubuntu) OpenSSL/3.0.2 configured -- resuming normal operations
[Mon Sep 14 09:40:53.682417 2026] [core:notice] [pid 2242:tid 140274110928768] AH00094: Command line: '/
usr/sbin/apache2'
```

Two logs, and the split matters: `access.log` is one line per request, `error.log` is where Apache explains itself. When a site returns 500 the useful line is almost never in the first file.

5. Verification

```
Exercise 1: All 8 checks passed
Exercise 2: All 6 checks passed
Exercise 3: All 8 checks passed
Exercise 4: All 3 checks passed
Exercise 5: All 5 checks passed
Exercise 6: All 5 checks passed
Exercises run:      6
Exercises passed:   6
Exercises failed:   0
Exercises skipped:  0
All exercises passed!
```

6. What to take away

- The MPM decides the concurrency model. `event` by default; `prefork` when a module is not thread-safe.
- Apache is modules: if a feature is missing, the module is probably just not enabled. `a2enmod`, then reload.
- Self-signed means subject equals issuer. The traffic is still encrypted; what is absent is a third party vouching for the identity.
- `-k` in curl, and "proceed anyway" in a browser, are the same decision: skip verification. Know when you are making it.
- Set `ServerName` globally, or Apache will guess one.
- `access.log` for what was asked, `error.log` for why it went wrong.

`guide.md` in the plugin carries the exercises: issuing the certificate, virtual hosts, `.htaccess` and access control, and reading the logs.